МИНИСТЕРСТВО ЦИФРОВЫХ ТЕХНОЛОГИЙ РЕСПУБЛИКИ УЗБЕКИСТАН
ТАШКЕНТСКИЙ УНИВЕРСИТЕТ ИНФОРМАЦИОННЫХ ТЕХНОЛОГИЙ ИМЕНИ МУХАММАДА АЛ-ХОРАЗМИЙ

Дисциплина: «Введение в программную инженерию»

ПРАКТИЧЕСКАЯ РАБОТА № 10

Тема 10. Инжиниринг безопасности: случаи злоупотребления, модель угроз и требования безопасности

Вариант № 8
«Разработка умного сайта для заказа услуг»

Выполнила: студентка группы M320-24 ДИР
Камбарова Хатича

Проверила: Латипова Нодира

Ташкент — 2026

1. Тема практической работы

Инжиниринг безопасности: случаи злоупотребления, модель угроз и требования безопасности.

Цель работы: закрепить теоретические знания; научиться выявлять активы и угрозы безопасности программной системы, описывать случаи злоупотребления, строить модель угроз по STRIDE, оценивать и приоритизировать риски безопасности, выбирать меры смягчения угроз и формулировать проверяемые требования безопасности.

2. Краткое описание проекта и использованные результаты

Вариант № 8: «Разработка умного сайта для заказа услуг». **«XizmatGo»** — веб-сайт (SPA/PWA) для заказа бытовых услуг в г. Ташкенте: клиент входит по SMS-коду, оформляет заказ с адресом и фото, система подбирает мастера, клиент оплачивает онлайн через Payme / Click / Uzum и оставляет отзыв. Система обрабатывает персональные данные (телефоны, адреса), платежи и документы мастеров, поэтому защищённость была признана характеристикой качества № 1 (ПР-9).

Таблица 2.1 — Использованные результаты практических работ

ПР	Результат	Использование в ПР-10
5	Акторы, варианты использования UC-01…UC-13, требования FR-01…FR-12, NFR-04 (безопасность), NFR-05 (данные в РУз)	Варианты использования для случаев злоупотребления; акторы — основа перечня злоумышленников
6	Подсистемы SS-1…SS-7 и INF-1…INF-5, интерфейсы, диаграмма развёртывания (Nginx, API, Celery, PostgreSQL, Redis, MinIO, внешние системы, порты)	Места хранения активов, процессы и хранилища DFD, границы доверия, точки входа
9	Ранжирование характеристик (защищённость — 1-е место), QR-01 (0 уязвимостей Critical/High), QR-02 (100 % поддельных callback отклонено), план SQA (OWASP ZAP, тест на проникновение)	Приоритеты, способы проверки требований безопасности

3. Активы системы и возможные злоумышленники

Свойства безопасности: **К** — конфиденциальность, **Ц** — целостность, **Д** — доступность, **П** — подлинность (аутентичность), **Н** — неотказуемость.

Таблица 3.1 — Активы системы

ID	Актив	Место хранения / обработки (ПР-6)	Важные свойства	Последствия ущерба	Ценность
A-01	Персональные данные клиентов (имя, телефон, адреса, история заказов)	D1 PostgreSQL; SS-1, SS-3; браузер клиента	К, Ц	Нарушение закона РУз «О персональных данных», штрафы, утрата доверия; адреса квартир — риск для безопасности людей	Высокая
A-02	Учётные записи и сессии (SMS-коды, JWT-токены)	D2 Redis; SS-1 (IAuth); API-шлюз	К, П	Захват аккаунта: заказы от имени клиента, доступ к его адресам; захват аккаунта мастера — заказы и выплаты	Высокая
A-03	Платёжные транзакции и статусы оплаты	D1; SS-5; Payme / Click / Uzum	Ц, П, Н	Услуга без оплаты, потеря комиссии, двойные списания, споры и возвраты	Высокая
A-04	Заказы, цены и статусы	D1; SS-3, SS-4	Ц, Д, Н	Подмена цены, отказ от выполненной работы, срыв заказов	Высокая
A-05	Данные мастеров: документы (паспорт), рейтинг, отзывы	D3 MinIO (документы); D1 (рейтинг); SS-6	К, Ц	Утечка паспортных данных; накрутка рейтинга искажает подбор и обманывает клиентов	Высокая
A-06	Фото заказов	D3 MinIO; INF-3	К	Фото квартир с геометкой раскрывают обстановку и адрес	Средняя
A-07	Секреты: ключи API Payme, Click, Eskiz, ключ подписи JWT, пароли БД	Файл .env на VPS-1, CI GitHub	К	Полная компрометация: подделка токенов, платёжных запросов, рассылка SMS за счёт компании	Критическая
A-08	Журнал аудита (действия модераторов, смены статусов и цен)	D4 (только запись)	Ц, Н	Невозможно разобрать спор или расследовать инцидент	Средняя
A-09	Доступность сервиса (сайт, API, SMS-рассылка)	VPS-1, VPS-2, Eskiz	Д	Потеря заказов и комиссии; расходы на SMS при злоупотреблении	Средняя

Таблица 3.2 — Возможные злоумышленники

ID	Злоумышленник	Мотивация	Возможности	Целевые активы
Z-1	Внешний злоумышленник	Кража данных и аккаунтов для перепродажи, вымогательство	Средние–высокие, автоматические инструменты	A-01, A-02, A-07
Z-2	Мошенник-клиент	Получить услугу без оплаты, вернуть деньги за выполненную работу	Низкие–средние	A-03, A-04
Z-3	Недобросовестный мастер	Накрутить рейтинг, получать больше заказов, обходить комиссию, собирать контакты клиентов	Низкие, но доступ к своему кабинету	A-04, A-05, A-01
Z-4	Инсайдер (модератор, бывший сотрудник)	Корысть, месть	Высокие: легальный доступ к админ-панели	A-01, A-05, A-08
Z-5	Конкурент, ботоводы	Вывести сервис из строя в часы пик, выкачать каталог и цены, израсходовать SMS-баланс	Средние, ботнеты	A-09

4. Случаи злоупотребления

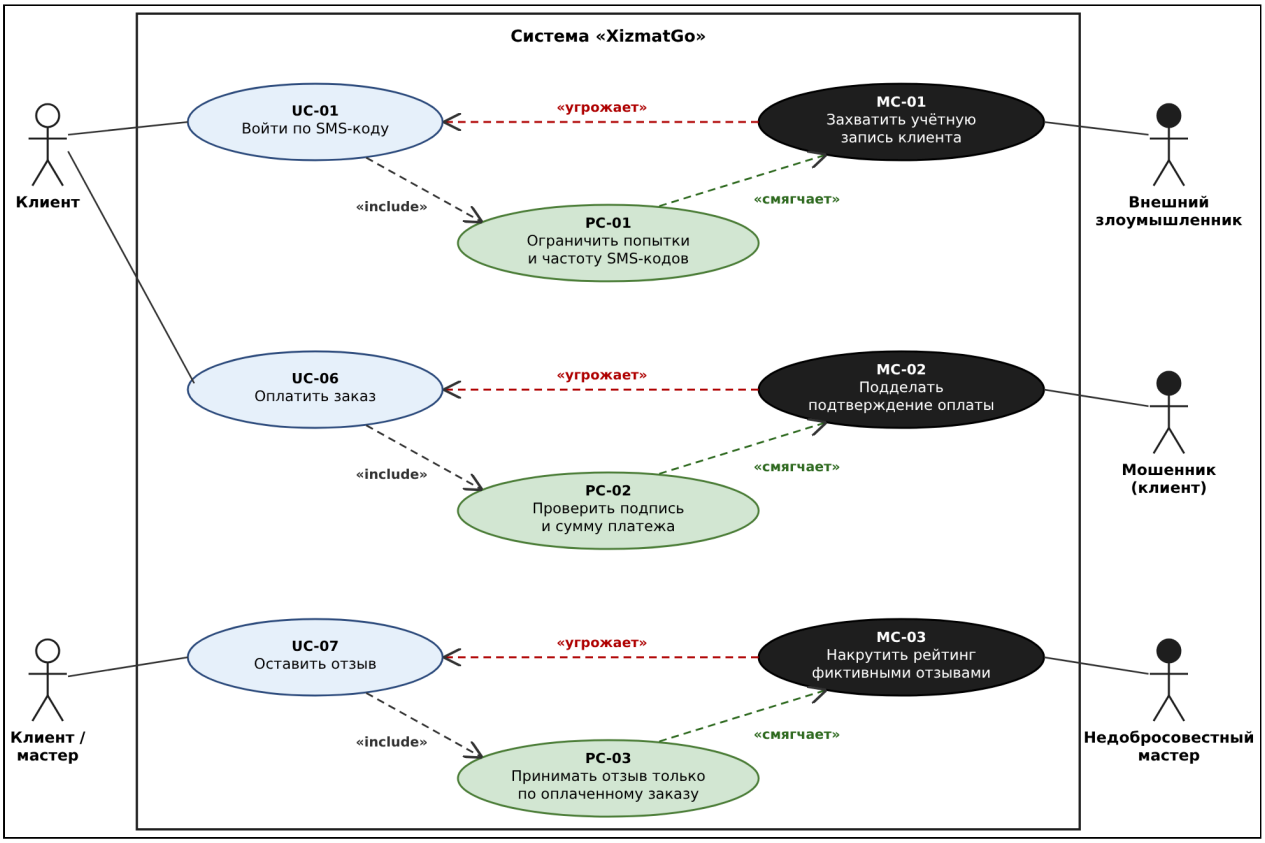


Рисунок 4.1 — UML-диаграмма случаев злоупотребления (чёрные — случаи злоупотребления, зелёные — защитные варианты использования)

Таблица 4.1 — МС-01 «Захватить учётную запись клиента»

Злоумышленник	Z-1 Внешний злоумышленник (также Z-5 — боты)
Угрожает	UC-01 «Войти по SMS-коду»; активы A-02, A-01
Предусловия	Злоумышленнику известен номер телефона жертвы (из открытых источников)
Сценарий злоупотребления	1. Злоумышленник запрашивает SMS-код на номер жертвы. 2. Автоматически перебирает 6-значные коды в API проверки. 3. При отсутствии ограничений угадывает код и получает токен сессии. 4. Просматривает адреса и историю заказов, оформляет заказы от имени жертвы.
Альтернатива	2a. Многократно запрашивает коды на разные номера — расходует SMS-баланс компании (SMS pumping).
Защитный ВИ (смягчает)	**РС-01 «Ограничить попытки и частоту SMS-кодов»**: не более 5 попыток ввода на код, затем блокировка на 15 минут; не более 3 кодов на номер в 10 минут и 10 в сутки; ограничение запросов с одного IP; CAPTCHA после превышения порога; уведомление владельца о входе с нового устройства
Последствия при успехе	Утечка ПД, мошеннические заказы, финансовые потери

Таблица 4.2 — МС-02 «Подделать подтверждение оплаты»

Злоумышленник	Z-2 Мошенник-клиент (или Z-1)
Угрожает	UC-06 «Оплатить заказ»; актив A-03
Предусловия	Злоумышленник знает адрес callback-эндпоинта и формат уведомления (например, из трафика своего браузера)
Сценарий злоупотребления	1. Оформляет заказ, мастер выполняет работу. 2. Вместо оплаты отправляет на callback-эндпоинт поддельное уведомление «оплата успешна» или повторяет старое уведомление от другого заказа. 3. Если система не проверяет подлинность, заказ получает статус «Оплачен», мастеру начисляется доход, которого нет.
Защитный ВИ (смягчает)	**РС-02 «Проверить подпись и сумму платежа»**: проверка подписи / авторизации запроса по секретному ключу провайдера; приём только с IP-адресов провайдера; сверка суммы, валюты и номера заказа; защита от повторов (идемпотентность по ID транзакции); дополнительная проверка статуса запросом к API провайдера
Последствия при успехе	Неоплаченные услуги, долги перед мастерами, споры

Таблица 4.3 — МС-03 «Накрутить рейтинг фиктивными отзывами»

Злоумышленник	Z-3 Недобросовестный мастер
Угрожает	UC-07 «Оставить отзыв» и косвенно UC-04 «Подобрать мастера»; актив A-05
Сценарий злоупотребления	1. Мастер регистрирует несколько клиентских аккаунтов на номера знакомых. 2. Оформляет фиктивные заказы на себя и отмечает их выполненными. 3. Оставляет отзывы 5 ★ и поднимает рейтинг; алгоритм подбора начинает рекомендовать его первым.
Защитный ВИ (смягчает)	**РС-03 «Принимать отзыв только по оплаченному заказу»**: отзыв возможен только после завершённого и оплаченного (или подтверждённого обеими сторонами) заказа; один отзыв на заказ; учёт отзывов в рейтинге с весом по возрасту аккаунта; правила антифрода (совпадение устройства или адреса клиента и мастера, серия заказов «по кругу») с передачей подозрительных случаев модератору
Последствия при успехе	Клиенты получают ненадёжных мастеров; падение доверия к рейтингу

5. DFD, поверхность атаки и модель угроз STRIDE

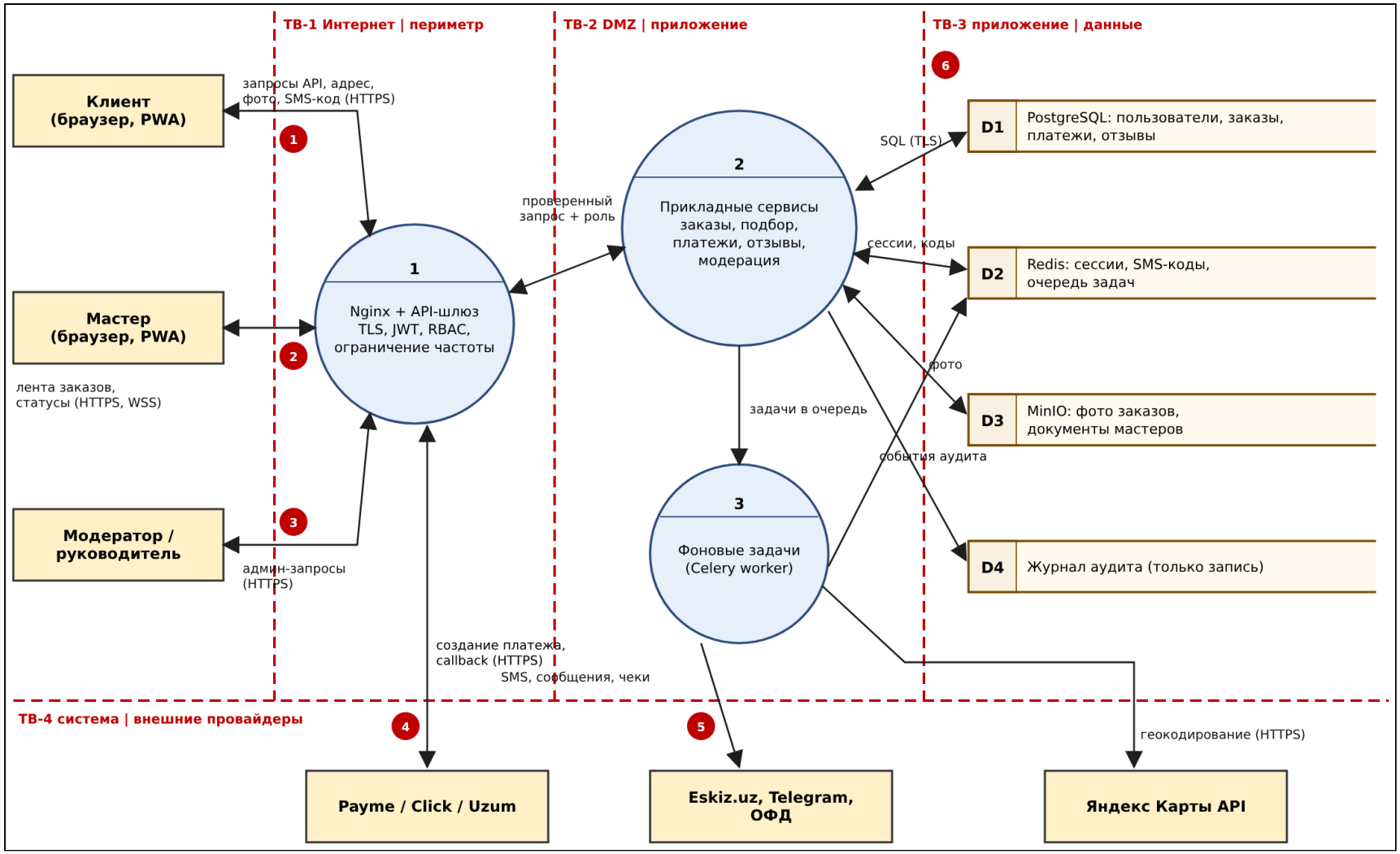


Рисунок 5.1 — Диаграмма потоков данных системы «XizmatGo» с границами доверия ТВ-1…ТВ-4 и точками входа 1–6

Обозначения DFD: прямоугольники — внешние сущности, круги — процессы, открытые прямоугольники — хранилища данных, стрелки — потоки данных, красные пунктирные линии — границы доверия, красные кружки — точки входа. Каждый поток, пересекающий границу доверия, — место, где данные нужно проверять, а канал — защищать.

Таблица 5.1 — Точки входа (поверхность атаки) и меры её сокращения

EP	Точка входа	Доступ	Меры сокращения поверхности атаки
1	Публичный REST API клиента (/api/v1: каталог, поиск, заказы, загрузка фото, /auth/send-code, /auth/verify)	Анонимный и после входа	Анонимно доступны только каталог, поиск и вход; остальные эндпоинты — только с токеном; отключены неиспользуемые методы HTTP и отладочные эндпоинты; ограничение частоты запросов в Nginx; ограничение размера тела запроса
2	API и WebSocket мастера (лента заказов, смена статусов)	Роль «мастер»	Доступ только верифицированным мастерам; лента отдаёт адрес без номера квартиры до принятия заказа; WebSocket только по WSS с токеном
3	Админ-панель модератора и руководителя	Роли «модератор», «руководитель»	Отдельный поддомен, доступ только из офисной сети / VPN по списку IP, вход с двухфакторной аутентификацией; принцип минимальных прав
4	Callback-эндпоинт платёжных систем	Внешние системы	Принимает только POST от IP-адресов провайдеров, с проверкой подписи; отдельный путь, не связанный с пользовательским API
5	Исходящие интеграции (Eskiz, Telegram, ОФД, Яндекс Карты)	Система	Только HTTPS с проверкой сертификата; ключи в хранилище секретов; лимиты расходов в кабинете Eskiz
6	Администрирование серверов (SSH, порты 5432, 6379, 9000)	Администраторы	SSH только по ключам и через VPN; порты БД, Redis и MinIO закрыты извне (частная сеть VPS-1 ↔ VPS-2); отключён вход root

Таблица 5.2 — Модель угроз STRIDE (12 угроз, 6 категорий)

ID	STRIDE	Угроза	Элемент DFD / EP	Злоумышленник	Актив
T-01	S — подмена	Подбор SMS-кода и вход в чужую учётную запись (MC-01)	Процесс 1, 2; EP-1	Z-1	A-02, A-01
T-02	S — подмена	Поддельное или повторное уведомление платёжной системы об успешной оплате (MC-02)	Поток Payme → процесс 1; EP-4	Z-2, Z-1	A-03
T-03	T — изменение	Изменение цены или суммы заказа в запросе от браузера	Поток клиент → процесс 1; EP-1	Z-2	A-04, A-03
T-04	T — изменение	Накрутка рейтинга фиктивными заказами и отзывами (MC-03)	Процесс 2, D1	Z-3	A-05
T-05	R — отказ от действий	Мастер отрицает, что изменил итоговую цену; клиент отрицает получение услуги	Процесс 2, D4	Z-2, Z-3	A-04, A-08
T-06	I — раскрытие	Доступ к чужим заказам и адресам перебором идентификаторов в URL (IDOR)	Процесс 2; EP-1, EP-2	Z-1, Z-3	A-01, A-04
T-07	I — раскрытие	Утечка ключей API и ключа подписи JWT из репозитория, логов или CI	Процесс 2, 3; EP-6	Z-1, Z-4	A-07
T-08	I — раскрытие	Раскрытие адреса через метаданные (GPS) фото и публичные ссылки на файлы	D3; EP-1	Z-1, Z-3	A-06, A-05
T-09	D — отказ в обслуживании	Массовые запросы SMS-кодов (SMS pumping): расход баланса и блокировка рассылки	Процесс 1, 3; EP-1, EP-5	Z-5	A-09
T-10	D — отказ в обслуживании	Перегрузка поиска и API ботами в часы пик	Процесс 1, 2; EP-1	Z-5	A-09
T-11	E — повышение привилегий	Пользователь получает доступ к функциям модератора: изменение роли в запросе или эндпоинт админки без проверки роли	Процесс 1, 2; EP-1, EP-3	Z-1, Z-3	A-01, A-05, A-08
T-12	E — повышение привилегий	Загрузка вредоносного файла под видом фото для выполнения кода на сервере	Процесс 2, D3; EP-1	Z-1	все

Покрыты все 6 категорий STRIDE: S — 2, T — 2, R — 1, I — 3, D — 2, E — 2.

6. Оценка и приоритизация рисков, меры смягчения и требования безопасности

Шкалы. Вероятность (В) и ущерб (У): 1 — низкий, 2 — средний, 3 — высокий. Риск = В × У: 6–9 — высокий, 3–4 — средний, 1–2 — низкий. Реакции: **снизить** (контрмеры), **передать** (третьей стороне), **избежать** (отказаться от функции или данных), **принять** (осознанно оставить).

Таблица 6.1 — Оценка рисков, приоритеты, реакции и контрмеры

Приор.	ID	Угроза	В	У	Риск	Реакция	Контрмеры	Треб.
1	T-06	IDOR — чужие заказы и адреса	3	3	**9 высокий**	Снизить	Проверка владельца объекта на каждом запросе на сервере; UUID вместо последовательных номеров; автотесты «чужой токен → 403»	SR-04
2	T-01	Подбор SMS-кода	2	3	**6 высокий**	Снизить	Лимит попыток и блокировка; лимит кодов на номер и IP; одноразовый код с коротким сроком; уведомление о новом входе	SR-01
3	T-02	Поддельный callback оплаты	2	3	**6 высокий**	Снизить	Проверка подписи и IP провайдера, сверка суммы и номера заказа, идемпотентность, повторная проверка статуса через API	SR-02
4	T-03	Подмена цены в запросе	3	2	**6 высокий**	Снизить	Цена всегда пересчитывается на сервере (PriceCalculator); значения цены от клиента игнорируются	SR-03
5	T-09	SMS pumping	3	2	**6 высокий**	Снизить + передать	Лимиты частоты, CAPTCHA, запрет международных номеров; лимит расходов и антифрод на стороне Eskiz (частично передан провайдеру)	SR-01, SR-09
6	T-04	Накрутка рейтинга	2	2	**4 средний**	Снизить	Отзыв только по оплаченному заказу, правила антифрода, ручная проверка подозрительных случаев	SR-06
7	T-05	Отказ от действий	2	2	**4 средний**	Снизить	Журнал аудита только на запись; подтверждение клиентом итоговой цены, если она выше предварительной на 30 % (ПР-1); временные метки статусов	SR-05
8	T-10	Перегрузка ботами	2	2	**4 средний**	Снизить + передать	Ограничение частоты в Nginx, кэш каталога в Redis; защита от DDoS у хостинг-провайдера	SR-09
9	T-07	Утечка секретов	1	3	**3 средний**	Снизить	Секреты только в переменных окружения и хранилище CI; сканирование секретов в CI; запрет вывода секретов в логи; ротация ключей	SR-07

10	T-11	Повышение до модератора	1	3	**3 средний**	Снизить	Роль берётся только из БД на сервере, не из запроса; проверка роли на каждом эндпоинте; админка за VPN и с 2FA	SR-04, SR-10
11	T-12	Вредоносный файл	1	3	**3 средний**	Снизить	Проверка типа по содержимому, лимит размера, перекодирование изображений, хранение вне сервера приложений без права выполнения	SR-08
12	T-08	Метаданные фото, публичные ссылки	1	2	2 низкий	Снизить (дёшево)	Удаление EXIF при перекодировании; закрытый бакет и временные подписанные ссылки — выполняются в рамках SR-08	SR-08

Итого: высоких рисков — 5, средних — 6, низких — 1. Принятых без мер угроз нет. Риск T-08 низкий, но закрывается без дополнительных затрат той же мерой, что и T-12.

Таблица 6.2 — Проверяемые требования безопасности

ID	Вид	Требование («Система должна…»)	Угрозы	Способ проверки
SR-01	Аутентификация	Ограничивать ввод SMS-кода 5 попытками на код с блокировкой на 15 мин; выдавать не более 3 кодов на номер за 10 мин и 10 в сутки; код — 6 цифр, срок действия 3 мин, одноразовый	T-01, T-09	Автотест API: 6-я попытка → 429 и блокировка; 4-й код за 10 мин → отказ; повторное использование кода → 401
SR-02	Целостность, подлинность	Принимать уведомления об оплате только с проверенной подписью / авторизацией провайдера и с IP-адресов провайдера; сверять сумму, валюту и номер заказа; обрабатывать каждую транзакцию один раз	T-02	Автотесты: 30 поддельных запросов (неверная подпись, чужая сумма, повтор) → 100 % отклонено (QR-02 из ПР-9); проверка журнала
SR-03	Целостность данных	Рассчитывать предварительную и итоговую стоимость только на сервере; игнорировать любые значения цены и суммы, переданные клиентом	T-03	Автотест: запрос с изменённым полем price → сохранена серверная цена; ревью кода сериализаторов
SR-04	Авторизация	Проверять на сервере права пользователя на каждый объект (заказ, адрес, отзыв, документ) и роль на каждый эндпоинт; по умолчанию запрещать доступ; использовать непоследовательные идентификаторы (UUID)	T-06, T-11	Набор автотестов «чужой токен / токен другой роли → 403» для всех эндпоинтов; тест на проникновение (IDOR)
SR-05	Аудит, неотказуемость	Записывать в журнал только на запись все смены статуса и цены заказа и действия модераторов (кто, что, когда, IP); хранить 1 год; запрашивать подтверждение клиента при росте цены более чем на 30 %	T-05, T-04	Тест: смена цены → запись в журнале; попытка изменить или удалить запись журнала пользователем приложения → отказ на уровне прав БД

SR-06	Бизнес-логика, антифрод	Принимать отзыв только по завершённому и оплаченному заказу, один на заказ; помечать для проверки модератором серии заказов с совпадающими устройством или адресом клиента и мастера	T-04	Автотесты: отзыв до оплаты → отказ, повторный → отказ; тест правила антифрода на подготовленных данных
SR-07	Конфиденциальность (секреты)	Хранить ключи и пароли только в переменных окружения и хранилище секретов CI; не записывать их в репозиторий и логи; менять ключи не реже раза в год и сразу при подозрении на утечку	T-07	Сканер секретов (gitleaks) в CI — 0 находок; ревью конфигурации логирования; аудит SQA
SR-08	Входные данные, конфиденциальность	Принимать только JPG / PNG / PDF до 5 МБ с проверкой типа по содержимому; перекодировать изображения с удалением метаданных EXIF; хранить файлы в закрытом бакете и выдавать временные подписанные ссылки (≤ 15 мин)	T-12, T-08	Автотесты: файл с подменённым расширением → отказ; EXIF отсутствует после загрузки; прямая ссылка без подписи → 403
SR-09	Доступность	Ограничивать частоту запросов: не более 60 запросов в минуту с IP для публичных эндпоинтов и 5 в минуту для отправки SMS; показывать CAPTCHA после превышения; кэшировать каталог	T-09, T-10	Нагрузочный тест k6: при превышении лимита → 429, сервис для остальных пользователей отвечает в пределах QR-08
SR-10	Авторизация, сеть	Открывать админ-панель только из разрешённых сетей (VPN) с двухфакторной аутентификацией; закрыть порты БД, Redis, MinIO и SSH от доступа из интернета	T-11, T-07	Сканирование портов извне (nmap) — открыты только 80/443; попытка входа в админку без VPN и 2FA → отказ

Таблица 6.3 — Проверка покрытия угроз высокого и среднего риска требованиями

Угроза	**T-06**	**T-01**	**T-02**	**T-03**	**T-09**	**T-04**	**T-05**	**T-10**	**T-07**	**T-11**	**T-12**
Риск	**9**	**6**	**6**	**6**	**6**	**4**	**4**	**4**	**3**	**3**	**3**
Требования	SR-04	SR-01	SR-02	SR-03	SR-01, 09	SR-05, 06	SR-05	SR-09	SR-07, 10	SR-04, 10	SR-08

Все 11 угроз высокого и среднего риска закрыты хотя бы одним проверяемым требованием. Требования безопасности добавляются в бэклог продукта с приоритетом Must, а их проверки — в план SQA из ПР-9 (автотесты в CI, OWASP ZAP, тест на проникновение перед релизом).

7. Вывод о проделанной работе

В практической работе по варианту № 8 «Разработка умного сайта для заказа услуг» выполнен инжиниринг безопасности системы «XizmatGo»:

1. На основе ПР-5, ПР-6 и ПР-9 выявлено 9 активов с местами хранения, важными свойствами безопасности и последствиями ущерба. Описано 5 типов злоумышленников с мотивацией и возможностями.
2. По шаблону описаны 3 случая злоупотребления: захват учётной записи, подделка подтверждения оплаты, накрутка рейтинга. Построена UML-диаграмма со злоумышленниками, защитными вариантами использования и связями «угрожает» и «смягчает».
3. Построена DFD с 4 границами доверия, перечислены 6 точек входа с мерами сокращения поверхности атаки. Составлена модель угроз STRIDE: 12 угроз всех 6 категорий.
4. Риски оценены по шкале 1–3 и упорядочены по приоритету: 5 высоких, 6 средних, 1 низкий. Для каждой угрозы выбраны реакция и контрмеры.
5. Сформулированы 10 проверяемых требований безопасности SR-01…SR-10 с видом и способом проверки. Матрица покрытия подтверждает, что каждая угроза высокого и среднего риска закрыта хотя бы одним требованием.

Модель угроз связывает активы и злоумышленников с конкретными проверяемыми требованиями. Это позволяет встроить безопасность в разработку с самого начала, а не исправлять уязвимости после запуска.